

AWS IAM Advanced Hands-On Labs Roadmap

Overview

This roadmap is designed to provide strong practical clarity on advanced AWS Identity and Access Management concepts commonly expected from a DevOps Engineer, Cloud Engineer, Platform Engineer, or Site Reliability Engineer with around 3–4 years of experience.

These labs are:

- Focused heavily on AWS IAM
- Real-world oriented
- Cost optimized
- Designed to be completed within 1–2 days
- Structured to cover maximum IAM concepts with minimum infrastructure

Recommended Execution Order

Order	Lab
1	IAM Policy Evaluation & Debugging
2	Conditional IAM Policies
3	ABAC Dynamic Access Control
4	Cross-Account AssumeRole + External ID
5	Permission Boundaries
6	Access Key Rotation Automation
7	SCP Region Restriction
8	Privilege Escalation Analysis
9	KMS Key Policies + IAM
10	IAM Incident Investigation with CloudTrail
11	Enforce IMDSv2
12	Restrict S3 Upload Size

Order	Lab
13	Role Chaining and Session Control
14	Least-Privilege IAM for Lambda Automation
15	IAM Access Analyzer for External Access Detection
16	Secure CI/CD Access Using OIDC Federation

Lab 1 — IAM Policy Evaluation & Debugging

Lab Objective

Understand how AWS evaluates IAM permissions internally and learn to troubleshoot real-world access denied issues using IAM evaluation logic, explicit deny analysis, and CloudTrail investigation.

Scenario

A DevOps engineer reports:

“The IAM policy looks correct, but access is still denied.”

This lab focuses on understanding how AWS evaluates IAM permissions internally.

Concepts Covered

- Identity-based policies
- Explicit deny vs allow
- Policy evaluation logic
- IAM debugging
- Context-based authorization

Services Involved

- Amazon S3
- AWS CloudTrail

Task Requirements

Create:

- One Allow policy for S3 access
- One Deny policy with conditions
- Attach both policies to a user or role
- Test access behavior

Debug failures using:

- IAM Policy Simulator
- CloudTrail logs

Advanced IAM Knowledge Gained

- How AWS evaluates multiple policies
- Why explicit deny always wins
- Real-world IAM troubleshooting approach

Validation

- Access succeeds under allowed conditions
- Access denied when deny condition matches

Estimated Time

 1 – 1.5 Hours

Difficulty

 Medium–Hard

Lab 2 — Create Conditional IAM Policies Based on Source IP and MFA

Lab Objective

Implement context-aware IAM authorization using MFA and source IP restrictions to enforce secure production access aligned with zero-trust security principles.

Scenario

Production access should only be allowed:

- From corporate networks
- With MFA enabled

Concepts Covered

- IAM Conditions
- MFA enforcement
- Source IP restriction
- Context keys
- Zero-trust access patterns

Services Involved

- AWS Identity and Access Management

Task Requirements

Create IAM policy enforcing:

- MFA authentication
- Specific IP range access
- Deny console/API access otherwise

Use condition keys:

- `aws:MultiFactorAuthPresent`
- `aws:SourceIp`

Validate using:

- AWS Console
- AWS CLI

Advanced IAM Knowledge Gained

- Context-aware authorization
- Conditional access models
- Security-focused IAM design

Validation

- Access denied without MFA
- Access denied outside approved IP range

Estimated Time

 1 Hour

Difficulty

 Medium–Hard

Lab 3 — Implement ABAC for Dynamic Access Control

Lab Objective

Learn how to implement scalable Attribute-Based Access Control (ABAC) using principal and resource tags to simplify enterprise IAM management.

Scenario

The organization wants scalable IAM authorization using tags instead of creating separate policies for each team.

Concepts Covered

- ABAC (Attribute-Based Access Control)
- Principal tags
- Resource tags
- IAM condition keys
- Dynamic authorization

Services Involved

- Amazon S3
- AWS Identity and Access Management

Task Requirements

Create resources tagged with:

- Team=Backend
- Team=Frontend

Create IAM policies using:

- `aws:PrincipalTag`
- `aws:ResourceTag`

Users should:

- Access only matching-tag resources
- Be denied cross-team access

Advanced IAM Knowledge Gained

- Enterprise IAM scalability patterns
- Dynamic authorization systems
- Policy simplification using tags

Validation

- Backend users denied access to Frontend resources

Estimated Time

 1.5 Hours

Difficulty

 Hard

Lab 4 — Cross-Account Secure Deployment Using AssumeRole + External ID

Lab Objective

Understand how secure cross-account authentication works using STS AssumeRole, trust policies, and External IDs to prevent confused deputy attacks.

Scenario

A DevOps account must securely deploy infrastructure into a Production account.

Concepts Covered

- Cross-account IAM
- STS AssumeRole
- Trust policies
- External ID
- Temporary credentials

Services Involved

- AWS Security Token Service
- AWS Identity and Access Management

Task Requirements

Create:

- One DevOps AWS account
- One Production AWS account

Create deployment role in Production account:

- Allow only DevOps account
- Enforce External ID validation
- Restrict session duration to 1 hour

Validate AssumeRole using AWS CLI.

Advanced IAM Knowledge Gained

- Difference between trust policy and permissions policy
- Cross-account authentication flow
- Confused deputy attack prevention

Validation

- AssumeRole succeeds only with correct External ID
- Unauthorized principals denied

Estimated Time

 1.5 – 2 Hours

Difficulty

 Hard

Lab 5 — Permission Boundaries for Developers

Lab Objective

Implement permission boundaries to safely delegate IAM management capabilities while preventing privilege escalation and excessive permissions.

Scenario

Developers should be allowed to create IAM roles, but privilege escalation must be prevented.

Concepts Covered

- Permission boundaries
- Delegated IAM administration
- Privilege control
- Least privilege

Services Involved

- AWS Identity and Access Management

Task Requirements

Create permission boundary policy.

Allow developers to:

- Create IAM roles
- Attach only approved permissions

Enforce mandatory boundary attachment.

Test role creation:

- With boundary
- Without boundary

Advanced IAM Knowledge Gained

- Safe IAM delegation
- Controlling maximum permissions
- Enterprise IAM governance

Validation

- Roles without boundaries denied
- Excessive permissions blocked

Estimated Time

 1 Hour

Difficulty

 Hard

Lab 6 — Access Key Rotation Automation

Lab Objective

Automate IAM credential lifecycle management by securely rotating access keys using serverless automation and secret storage mechanisms.

Scenario

Long-term access keys must be rotated automatically for security compliance.

Concepts Covered

- IAM access key lifecycle
- Credential rotation
- IAM automation
- Secrets management

Services Involved

- AWS Lambda
- AWS Secrets Manager
- Amazon CloudWatch

Task Requirements

Create Lambda automation to:

- Create new access key
- Disable old key
- Store new key securely
- Trigger rotation automatically

Advanced IAM Knowledge Gained

- Secure credential lifecycle
- IAM automation workflows
- Operational security practices

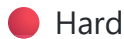
Validation

- Old key disabled successfully
- New key stored securely

Estimated Time

 1.5 Hours

Difficulty



Hard

Lab 7 — SCP for Region Restriction

Lab Objective

Implement organization-wide governance controls using Service Control Policies (SCPs) to restrict resource deployment to approved AWS regions.

Scenario

Organization policy requires all resources to stay within approved regions.

Concepts Covered

- Service Control Policies (SCP)
- Organization-wide governance
- Explicit deny precedence

Services Involved

- AWS Organizations

Task Requirements

Create SCP denying all regions except one.

Attach SCP to Organizational Unit.

Attempt resource creation in blocked region.

Advanced IAM Knowledge Gained

- Organization-level permission control
- SCP evaluation behavior
- Multi-account governance

Validation

- Resource creation denied in restricted regions

Estimated Time

 1 Hour

Difficulty

 Hard

Lab 8 — Analyze and Fix Privilege Escalation Paths

Lab Objective

Identify, analyze, and remediate IAM privilege escalation attack paths commonly exploited in insecure AWS environments.

Scenario

A security audit detected risky IAM permissions allowing privilege escalation.

Concepts Covered

- Privilege escalation
- IAM attack paths
- Security hardening
- Policy analysis

Services Involved

- AWS Identity and Access Management

Task Requirements

Create intentionally vulnerable role.

Analyze escalation paths involving:

- `iam:PassRole`
- `iam:AttachRolePolicy`
- `iam:UpdateAssumeRolePolicy`

Remediate vulnerabilities and re-test.

Advanced IAM Knowledge Gained

- Real-world IAM attack vectors
- IAM threat modeling
- Security remediation

Validation

- Escalation attempts fail after remediation

Estimated Time

 1.5 Hours

Difficulty

 Very Hard

Lab 9 — Build KMS Key Policies Integrated with IAM Permissions

Lab Objective

Understand the interaction between IAM policies and KMS key policies while implementing secure encryption access governance.

Scenario

Production applications require encrypted storage with tightly controlled decryption permissions.

Concepts Covered

- KMS key policies
- IAM + KMS interaction
- Encryption authorization
- Key administration separation

Services Involved

- AWS Key Management Service

Task Requirements

Create CMK.

Separate:

- Key administrators
- Key users

Allow decrypt only for approved roles.

Prevent accidental key deletion.

Advanced IAM Knowledge Gained

- Dual authorization model in KMS
- Cryptographic access governance
- Fine-grained encryption permissions

Validation

- Unauthorized principals cannot decrypt

Estimated Time

 1.5 Hours

Difficulty

 Hard

Lab 10 — Perform IAM Incident Investigation Using CloudTrail

Lab Objective

Perform IAM security investigations by tracing AssumeRole activity, session details, and user actions using CloudTrail logs.

Scenario

Suspicious AssumeRole activity detected in production.

Concepts Covered

- CloudTrail analysis
- IAM audit trails
- Session investigation
- Incident response

Services Involved

- AWS CloudTrail

Task Requirements

Generate AssumeRole activity and trace:

- Source IP
- User identity
- Session issuer
- Actions performed

Identify compromised permissions and apply remediation.

Advanced IAM Knowledge Gained

- IAM forensic analysis
- Session tracing
- Security investigation workflow

Validation

- Full activity timeline reconstructed

Estimated Time

 1 Hour

Difficulty

 Hard

Lab 11 — Enforce IMDSv2 on EC2

Lab Objective

Secure EC2 instance credentials by enforcing IMDSv2 and understanding how AWS protects metadata access against SSRF attacks.

Scenario

Prevent credential theft through SSRF attacks targeting EC2 metadata service.

Concepts Covered

- Instance metadata security
- IMDSv2 enforcement
- EC2 role credential protection

Services Involved

- Amazon EC2

Task Requirements

- Launch EC2 instance
- Require IMDSv2
- Test metadata access using curl

- Optionally enforce using SCP

Advanced IAM Knowledge Gained

- How EC2 role credentials work internally
- Metadata security best practices

Validation

- IMDSv1 requests blocked

Estimated Time

 45 Minutes

Difficulty

 Medium–Hard

Lab 12 — Restrict S3 File Upload Size

Lab Objective

Implement request-level IAM policy conditions to control S3 upload behavior and reduce unnecessary storage consumption.

Scenario

Prevent excessively large uploads to reduce unnecessary storage cost.

Concepts Covered

- S3 policy conditions
- Request-based authorization
- Storage governance

Services Involved

- Amazon S3

Task Requirements

Create policy restricting upload size using conditions.

Advanced IAM Knowledge Gained

- Request-level conditional enforcement
- Governance using IAM policies

Validation

- Oversized uploads denied

Estimated Time

 45 Minutes

Difficulty

 Medium–Hard

Lab 13 — Role Chaining and Session Control

Lab Objective

Understand how temporary credentials behave across multiple AssumeRole operations and implement secure role chaining controls.

Scenario

An operations engineer assumes multiple IAM roles across environments:

Dev → Shared Services → Production

The organization wants controlled session management and traceability.

Concepts Covered

- Role chaining
- STS session handling
- Session duration limits
- Session issuer tracking
- Temporary credentials lifecycle

Services Involved

- AWS Security Token Service
- AWS Identity and Access Management
- AWS CloudTrail

Task Requirements

Create:

- User or role A
- Intermediate role B
- Final production role C

Perform chained AssumeRole operations.

Restrict:

- Session duration
- Allowed principals

Track sessions using CloudTrail.

Advanced IAM Knowledge Gained

- Real-world multi-hop access models
- Temporary credential inheritance
- Session tracking during investigations

Validation

- Chained role access works
- Session duration restrictions enforced
- CloudTrail shows complete role chain

Estimated Time

 1.5 Hours

Difficulty

 Hard

Lab 14 — Build Least-Privilege IAM for Lambda Automation

Lab Objective

Design tightly scoped Lambda execution roles following least-privilege principles for secure automation workflows.

Scenario

A Lambda function automates infrastructure tasks and requires tightly scoped permissions.

The goal is to avoid excessive permissions like:

```
{  
  "Action": "*",  
  "Resource": "*"  
}
```

Concepts Covered

- Least privilege design
- Service roles
- IAM policy scoping
- Resource-level authorization
- Lambda execution roles

Services Involved

- AWS Lambda

- Amazon S3
- Amazon DynamoDB

Task Requirements

Create Lambda execution role.

Allow:

- Read access to one S3 bucket
- Write access to one DynamoDB table

Restrict all other access.

Test function behavior against unauthorized resources.

Advanced IAM Knowledge Gained

- Designing production-grade service roles
- Fine-grained execution permissions
- Secure automation architecture

Validation

- Lambda accesses only approved resources
- Unauthorized actions denied

Estimated Time

 1 – 1.5 Hours

Difficulty

 Hard

Lab 15 — IAM Access Analyzer for External Access Detection

Lab Objective

Learn how to identify, analyze, and remediate unintended external access to AWS resources using IAM Access Analyzer and least-privilege security practices.

Scenario

A security review identified that some AWS resources may be unintentionally accessible from outside the organization.

The goal is to detect and remediate overly permissive access.

Concepts Covered

- External access analysis
- Public resource exposure
- Cross-account access visibility
- Policy validation
- Least privilege remediation

Services Involved

- AWS IAM Access Analyzer
- Amazon S3

Task Requirements

- Enable IAM Access Analyzer
- Create intentionally risky resource policy:
 - Public S3 bucket access
 - OR cross-account access
- Run analysis
- Review generated findings
- Modify policies to remove unnecessary exposure

Advanced IAM Knowledge Gained

- How AWS identifies external access risks
- Difference between intended vs unintended access
- IAM auditing workflows used in enterprises

Validation

- Analyzer detects risky access
- Findings disappear after remediation

Estimated Time

 1 Hour

Difficulty

 Medium–Hard

Lab 16 — Secure CI/CD Access Using OIDC Federation

Lab Objective

Implement secure federated authentication for CI/CD pipelines using OIDC to eliminate long-term IAM access keys.

Scenario

A CI/CD pipeline should securely deploy infrastructure to AWS without storing long-term IAM access keys.

The organization wants modern federated authentication using OpenID Connect (OIDC).

Concepts Covered

- OIDC federation
- IAM role trust policies
- Short-lived credentials
- Secure CI/CD authentication
- Federated identity management

Services Involved

- AWS IAM
- AWS STS
- GitHub Actions or another CI/CD platform

Task Requirements

Create:

- OIDC identity provider
- IAM role for CI/CD pipeline
- Trust policy allowing specific repository access

Restrict:

- Repository access
- Branch access
- Workflow permissions

Validate deployment using temporary credentials.

Advanced IAM Knowledge Gained

- Secure modern CI/CD authentication
- Eliminating long-term credentials
- Federated workload identity patterns

Validation

- CI/CD pipeline successfully assumes IAM role
- Unauthorized repositories denied

Estimated Time

 1.5 Hours

Difficulty

 Very Hard

Final Outcome of This Roadmap

After completing these labs, you will gain strong hands-on expertise in:

- Advanced IAM authorization mechanisms
- IAM policy debugging
- ABAC authorization models
- Cross-account security
- Permission boundaries
- SCP governance
- IAM automation
- IAM incident investigation
- Privilege escalation prevention
- Secure temporary credential usage
- Encryption access control using KMS
- Secure CI/CD federation
- Enterprise-grade IAM architecture patterns
- IAM access auditing and external exposure detection

These labs collectively simulate many real-world IAM security and governance scenarios commonly encountered by experienced DevOps Engineers, Cloud Engineers, Platform Engineers, and SREs working in AWS production environments.